CryptoVault Exchange

- **Institution:** PES UNIVERSITY, BANGALORE
- **Department:** Department of Computer Science and Engineering
- **Project Title:** CryptoVault Exchange: SOC Framework Design
- **Team Members:** Kaveri Sharma (SRN: PES1UG23CS293) and Anvita Kulkarni (SRN: PES1UG23CS092)
- **Organization Overview:** CryptoVault is a FinTech startup specializing in cryptocurrency trading and digital asset custody. The platform manages "Hot Wallets" for liquidity and "Cold Storage" for security.
- **Security Goal:** To secure Hot Wallet Private Keys from exfiltration and ensure the integrity of the transaction ledger.

Asset & CIA Mapping

Asset ID	Asset Name	Description	Category
A-01	Hot Wallet Private Keys	Keys used to sign outgoing transactions	Data (Critical)
A-02	User KYC Database	Identity documents (Passports, IDs)	Data (Confidential)
A-03	Trading Engine Server	Algorithm matching buy/sell orders	Infrastructure

A-04	Web Frontend	Public website/app users interact with	Infrastructure

CIA Triad Mapping

- **Hot Wallet Keys:** High Confidentiality, Integrity, and Availability. If keys are viewed, funds are stolen; if altered, transactions fail.
- **User KYC:** High Confidentiality to prevent identity theft and legal fines, with Medium Integrity/Availability.
- **Web Frontend:** Low Confidentiality, but High Integrity and Availability to maintain user trust and prevent phishing.

Threat Modeling & Risk Analysis

Nation-State (e.g., Lazarus): High capability; motivated by financial gain to fund regimes.

Cyber Criminals: High capability; deploy ransomware or steal databases for blackmail.

Malicious Insiders: Medium capability; developers bypassing withdrawal limits or copying keys.

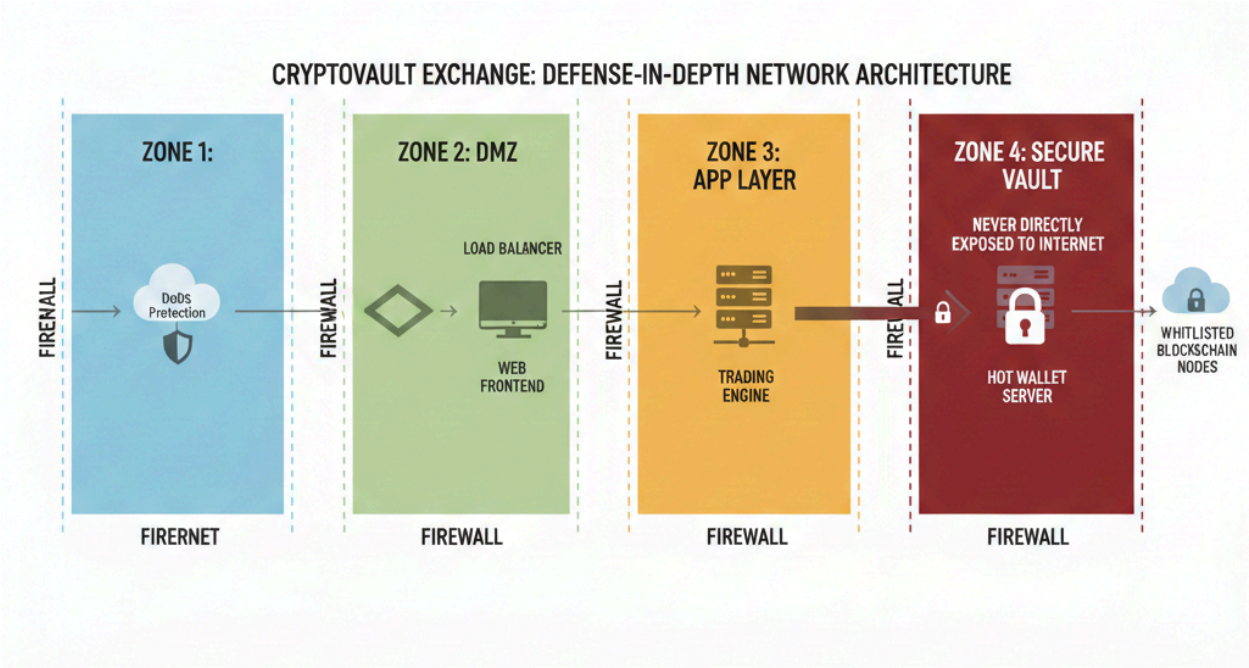
Protocol-Threat Mapping

- **HTTP/HTTPS (Web Attacks):** Phishing/XSS to steal 2FA codes and passwords.
- **DNS (Tunneling):** Malware on the Wallet Server hiding Command & Control (C2) commands inside DNS queries to bypass firewalls.
- **DHCP (Rogue Devices):** An attacker connects a physical device to the office network, spoofs the DHCP server, and intercepts admin traffic.

Network Architecture

The network is deeply segmented into four zones to ensure the Hot Wallet is never directly exposed to the internet:

1. **Zone 1 (Internet):** Entry point via DDoS protection.
2. **Zone 2 (DMZ):** Contains the Load Balancer and Web Frontend to sanitize inputs.
3. **Zone 3 (App Layer):** Contains the Trading Engine and KYC Database.
4. **Zone 4 (Secure Vault):** Contains the Hot Wallet Server; it only communicates with the Trading Engine and whitelisted Blockchain Nodes.



Log Source Identification & SOC Workflow

Source ID	Log Source	Log Type	Indicators of Compromise (IoC)

L-01	**Hot Wallet Server**	**Application Logs**	**Unexpected "Withdrawal" calls or large volume transfers.**
L-02	**Linux Systems**	**Syslogs/Auth.log**	**Root access attempts or modification of `authorized_keys`.**
L-03	**Network Firewall**	**Flow Logs**	**Outbound connections from the Hot Wallet to unknown IPs.**
L-04	**Cloud Console**	**Audit Logs**	**API calls to "Create Snapshot" or "Copy S3 Bucket".**

SOC Workflow

Step	Role	Key Output
Detection	**Tier 1**	**High-fidelity alert validation.**

Response	**Tier 2**	**Threatened asset isolation and wallet freezing.**
Prevention	**Tier 3**	**Blockchain forensics and malware signature updates.**

Phase 1: Alert Triage (Tier 1 – The Gatekeepers)

- Focus: High-volume, low-context monitoring of the exchange's "pulse".
  +1
- Crypto-Specific Triggers: * Monitoring for "Withdrawal Spikes" that exceed typical hourly liquidity patterns.
  +1
    - Flagging repeated "Failed 2FA" attempts on accounts holding significant digital assets.
    - Identifying "Outbound Tor Connections" originating from an administrator's terminal.
- Action: Verify if the alert is a "False Positive." If it’s a "True Positive," escalate immediately to Tier 2.

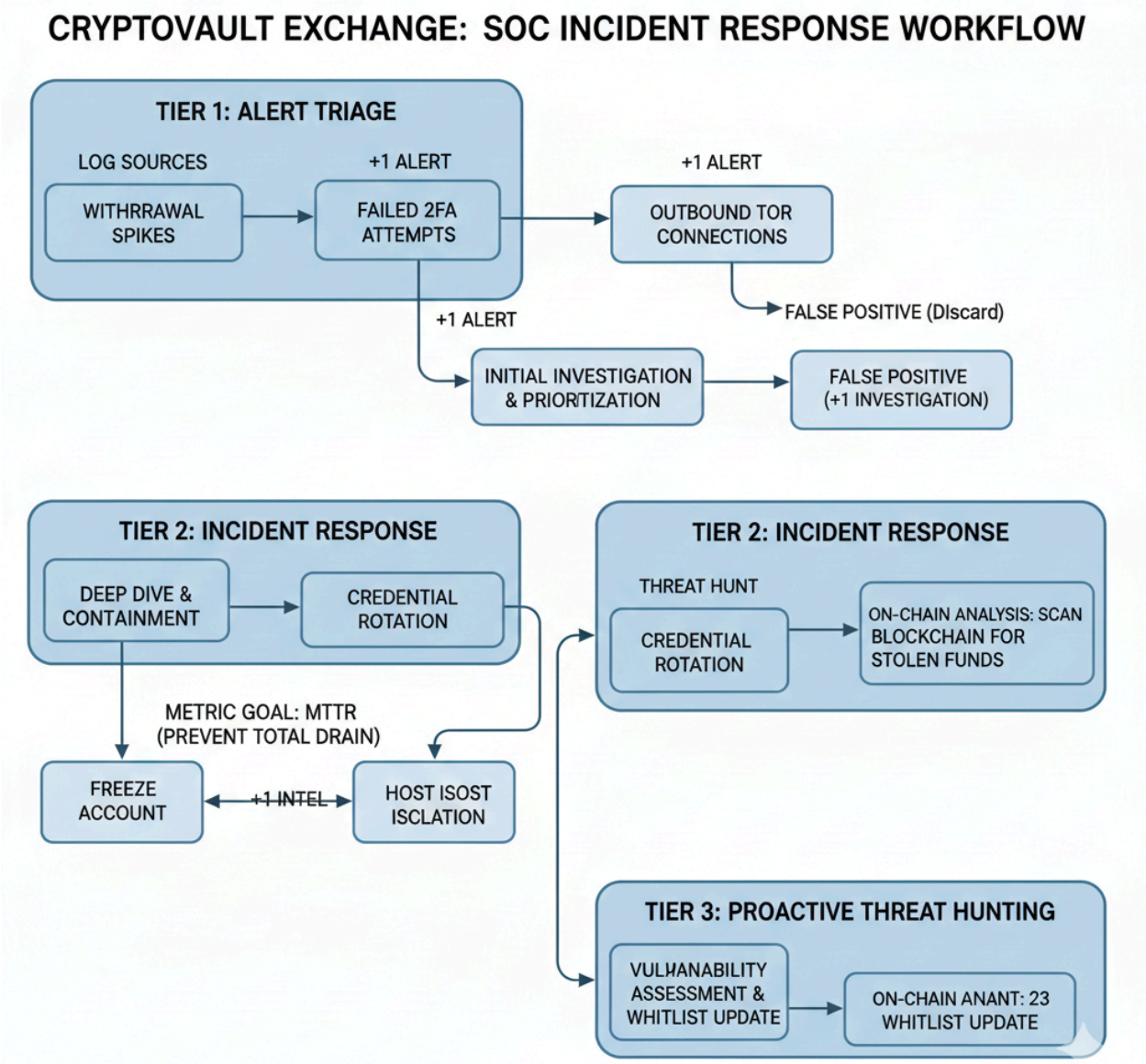
Phase 2: Investigation & Containment (Tier 2 – The Responders)

- Focus: Rapid deep-dive analysis to prevent a "Total Drain" of assets.
- Crypto-Specific Actions:
    - Freeze the Account: Instantly disabling the withdrawal function for the flagged user or admin.
    - Credential Rotation: Force-resetting private keys and API credentials if a leak is suspected.

    - Host Isolation: Disconnecting a compromised PC from the internal network to stop an attacker from reaching the Secure Vault (Zone 4).
- Metric Goal: Maintain an MTTR (Mean Time to Respond) that prevents a partial drain from becoming a total insolvency event.

Phase 3: Threat Hunting (Tier 3 – The Strategists)

- Focus: Proactive defense and forensic analysis of advanced threats.
- Crypto-Specific Actions:
    - On-Chain Analysis: Proactively scanning the blockchain for "tainted" funds or patterns associated with known threat actors like the Lazarus Group.
    - Malware Reverse Engineering: Analyzing the code found on employee laptops to identify if the attack was a targeted "Wallet Address Poisoning" attempt.
    - Vulnerability Assessment: Updating the "Secure Vault" whitelist to block new Command & Control (C2) IPs discovered during the hunt.



Metrics & Conclusion

MTTD (Mean Time To Detect): The average time to realize an intrusion has occurred. Crucial for CryptoVault: Must be <5 minutes, or funds are gone forever on the blockchain.

MTTR (Mean Time To Respond): The average time to contain a threat, such as freezing a wallet. This is the difference between a minor loss and total drainage.